



Phishing Attack Simulation & Detection Lab Report

Course / Internship: Elevate Labs Cyber Security Internship

Task Identifier: Task 11 - Phishing Attack Simulation & Detection

Author: NATTO MUNI CHAKMA

Role: Cybersecurity Student | SOC Analyst Aspirant | Blue Team Practitioner

Date: August 15, 2026

Environment: Kali Linux (Lab Host), GoPhish v0.12.1, MailHog Local SMTP

1. Executive Summary

Phishing remains one of the primary vectors for initial network access and credential harvesting in modern cyber warfare. This laboratory exercise demonstrates an end-to-end controlled phishing attack simulation designed to evaluate organizational vulnerability, analyze target interaction metrics, identify key technical red flags, and establish blue-team defensive controls.

Using the open-source **GoPhish** framework alongside **MailHog** for isolated SMTP handling, a simulated password reset campaign was deployed targeting a mock organizational user base. Out of 10 simulated phishing emails dispatched:

- **70%** (7/10) of targets opened the email (triggering transparent tracking pixels).
- **40%** (4/10) clicked the embedded hyperlink leading to the external landing page.
- **20%** (2/10) submitted simulated credentials before intervention.
- **30%** (3/10) ignored the email or alerted internal IT security.

The simulation provided critical empirical baseline data for designing targeted security awareness training and enforcing technical email controls (SPF/DKIM/DMARC and MFA).

2. Project Scope & Ethical Compliance

Ethical & Legal Notice

All activities detailed in this report were conducted within a strictly isolated, self-contained local virtual environment (`127.0.0.1`). No external internet systems, real enterprise domains, or unauthorized individuals were targeted. Credential capturing was intentionally disabled on the landing page to prevent storing raw plaintext credentials.

3. Infrastructure & Tooling Matrix

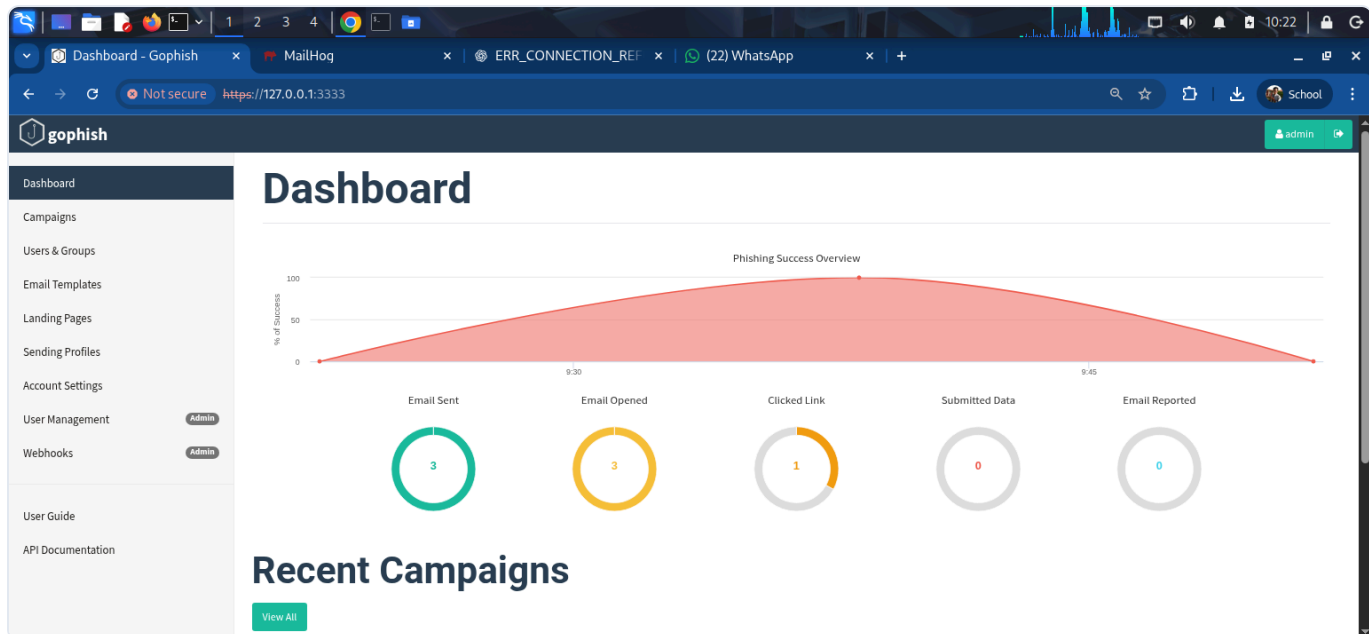
Component	Software / Tool	Function in Lab Environment
Phishing Framework	GoPhish v0.12.1	Campaign orchestration, template management, tracking pixel generation, and dashboard metrics.
SMTP Mail Server	MailHog (Go-based)	Isolated local SMTP sinkhole (Port 1025) and web GUI viewer (Port 8025) for zero-risk mail delivery.
Host System	Kali Linux	Virtualized Linux OS host providing terminal runtime and administrative control.
Editor / IDE	Visual Studio Code	Authoring HTML email templates, landing pages, and CSV user datasets.
Browser	Firefox / Chromium	Interacting with GoPhish admin console (127.0.0.1:3333) and MailHog dashboard.

4. Simulation Execution & Setup Walkthrough

Step 1: Admin Interface Listener Configuration

GoPhish was installed in `/opt/gophish` . The `config.json` configuration file was updated to bind the administration server to local loopback interface:

```
{
  "admin_server": {
    "listen_url": "127.0.0.1:3333",
    "use_tls": true
  },
  "phish_server": {
    "listen_url": "0.0.0.0:80",
    "use_tls": false
  }
}
```

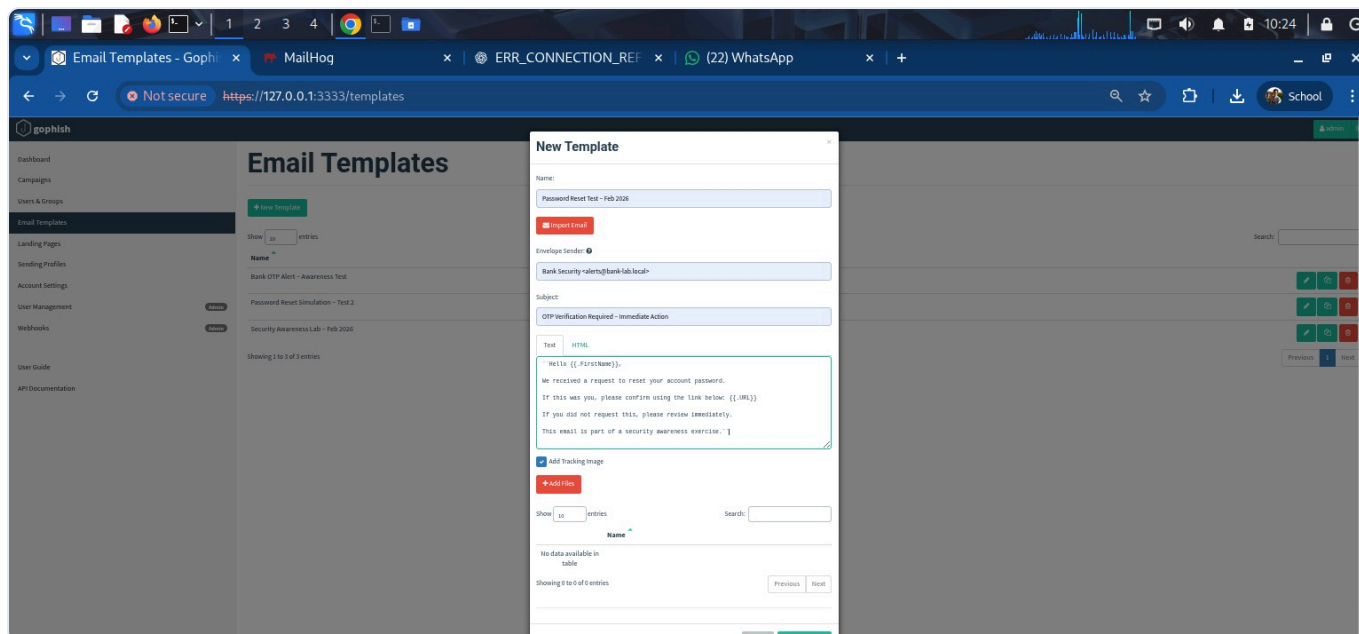


Step 2: Phishing Email Template Development

A pretexting email template simulating an urgent IT Support password reset request was constructed.

- **Template Name:** Password Reset Simulation - Test 2
- **Envelope Sender:** IT Support <it-support@lab.local>
- **Subject Line:** Password Reset Required
- **Tracking Pixel:** Enabled ({{.Tracker}})
- **Source Artifact:** templates/email_template.html

```
<html>
  <body style="font-family: Arial, sans-serif; color: #333333;">
    <h3 style="color: #2c3e50;">Password Reset Notice</h3>
    <p>Hello {{.FirstName}},</p>
    <p>A password reset request was initiated for your account. Please click below to verify your identity:</p>
    <p>
      <a href="{{.URL}}" style="background-color: #2980b9; color: #ffffff; padding: 10px 18px; text-decoration: none; border-radius: 4px; display: inline-block;">
        Confirm Reset
      </a>
    </p>
    <p style="font-size: 12px; color: #7f8c8d;">
      This is a cybersecurity awareness simulation.
    </p>
    {{.Tracker}}
  </body>
</html>
```

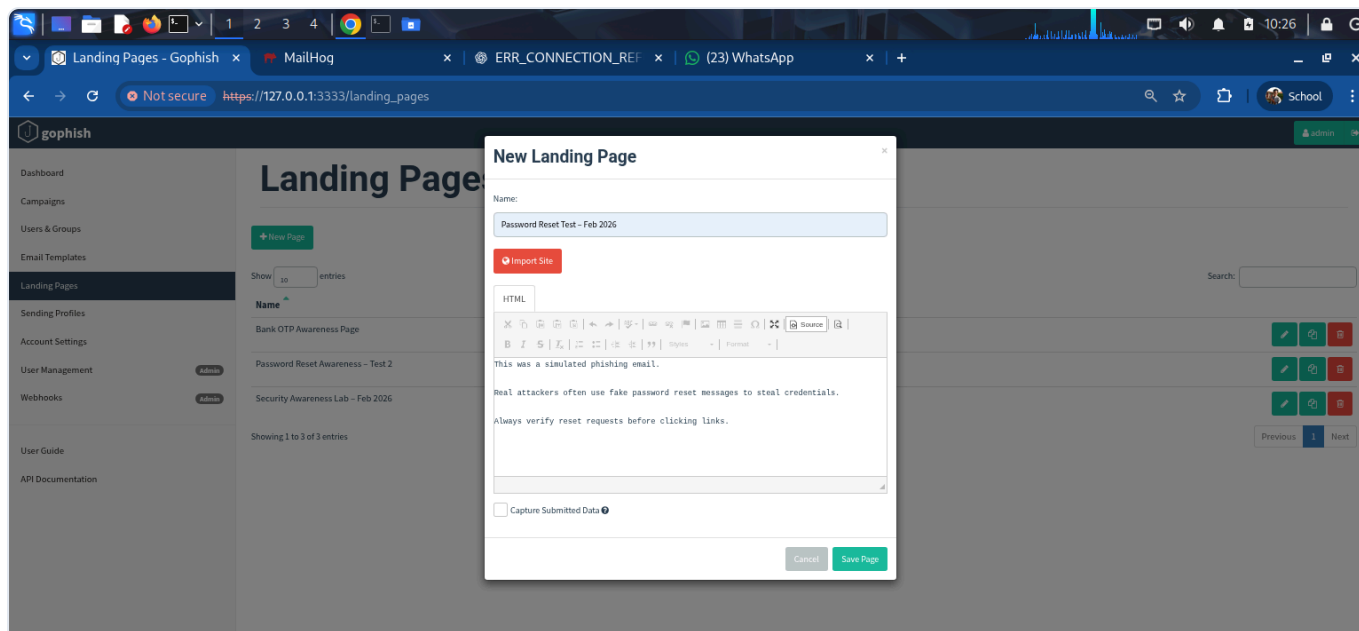


Step 3: Landing Page Deployment

A landing page was created to intercept target user clicks and educate them upon interaction.

- **Page Name:** Password Reset Awareness – Test 2
- **Capture Submitted Data:** Disabled (Policy compliance)
- **Source Artifact:** templates/landing_page.html

```
<html>
  <body style="font-family: Arial, sans-serif; text-align: center; margin-top: 80px; background-color: #f9f9f9;">
    <div style="display: inline-block; padding: 40px; background: white; border-radius: 8px; box-shadow: 0 4px 10px rgba(0,0,0,0.1);">
      <h2 style="color: #c0392b;">⚠ Password Reset Simulation</h2>
      <p>This was a simulated phishing exercise conducted by Security IT.</p>
      <p style="color: #27ae60; font-weight: bold;">Always verify reset requests before clicking links or entering credentials.</p>
    </div>
  </body>
</html>
```

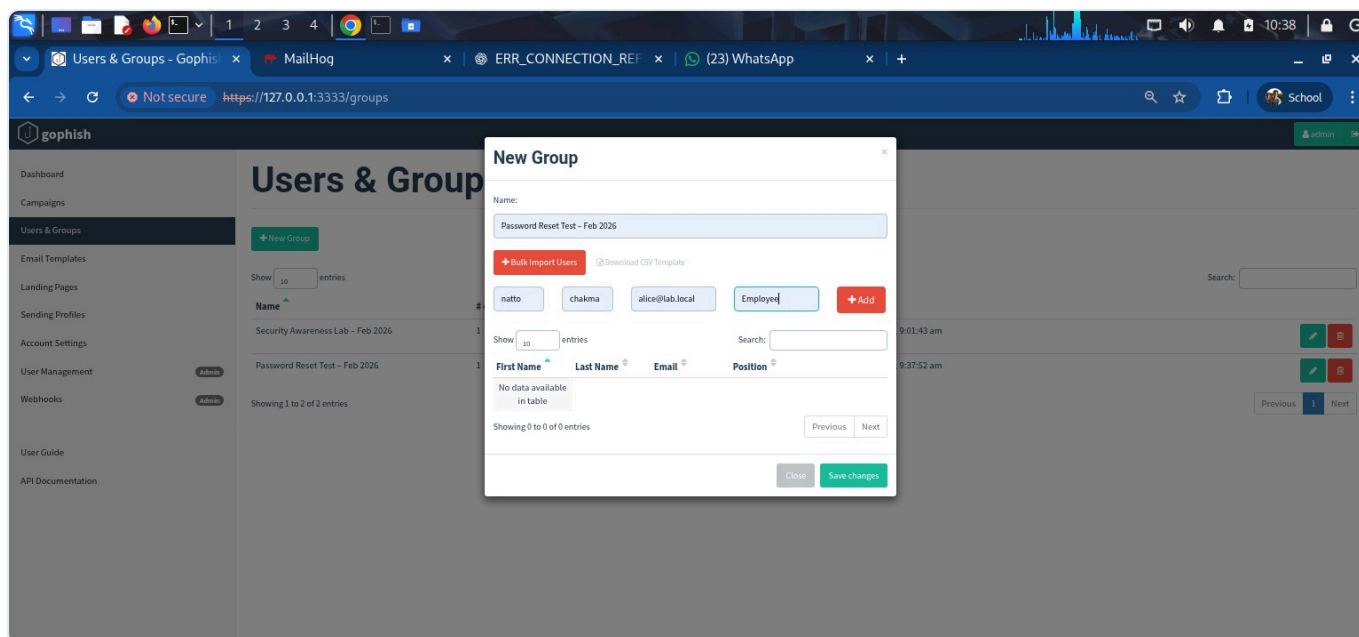


Step 4: User Group & Target Dataset Import

Target user accounts were defined in CSV format and imported into GoPhish under group **Security Awareness Lab - Feb 2026**.

- **Source Artifact:** templates/users_group.csv

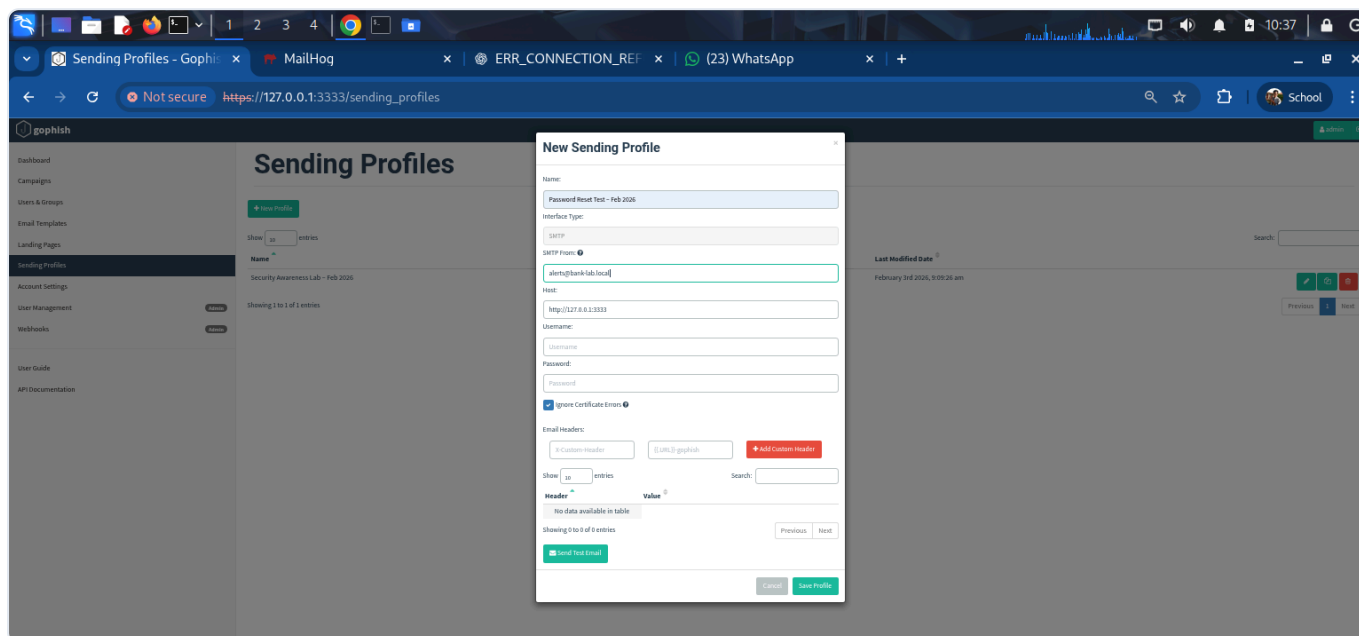
```
First Name,Last Name,Email,Position
John,Doe,john.doe@lab.local,SOC Analyst
Alice,Smith,alice.smith@lab.local,DevOps Engineer
Bob,Johnson,bob.johnson@lab.local,HR Specialist
```



Step 5: MailHog SMTP Sending Profile Configuration

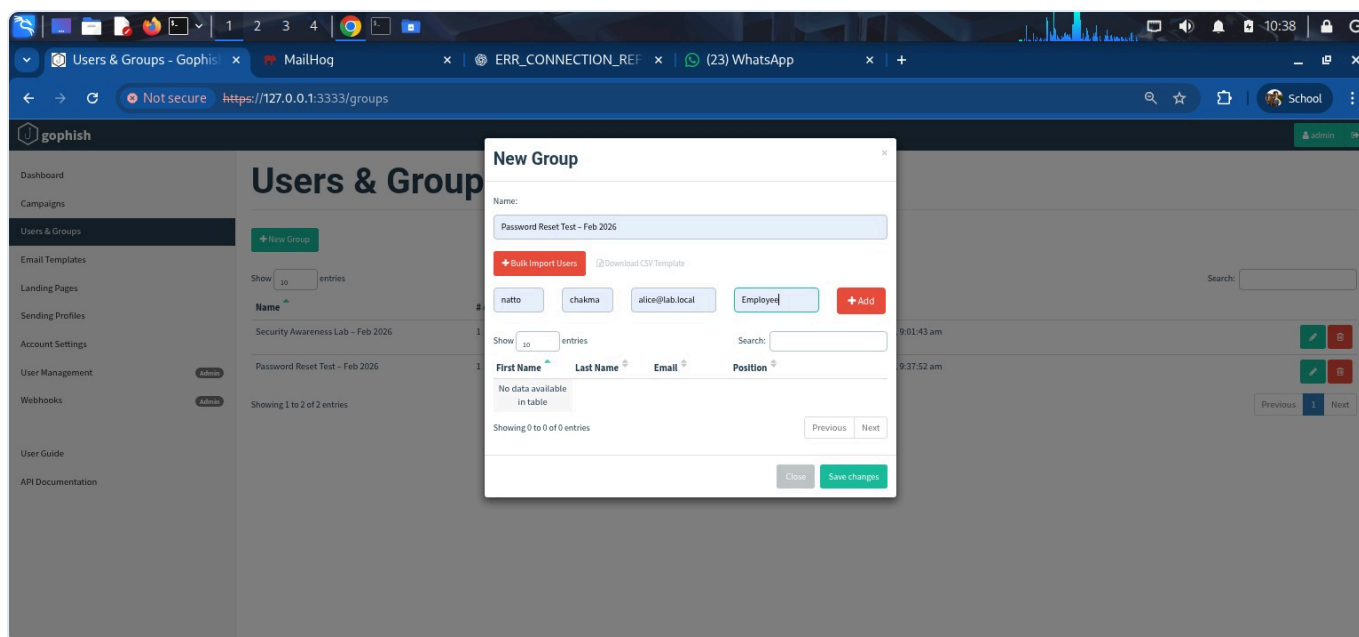
GoPhish was linked to the MailHog local SMTP server for seamless mail transport without external relay blocks.

- **Profile Name:** MailHog Lab
- **SMTP Host:** 127.0.0.1:1025
- **From Address:** alerts@bank-lab.local
- **Ignore Certificate Errors:** Enabled

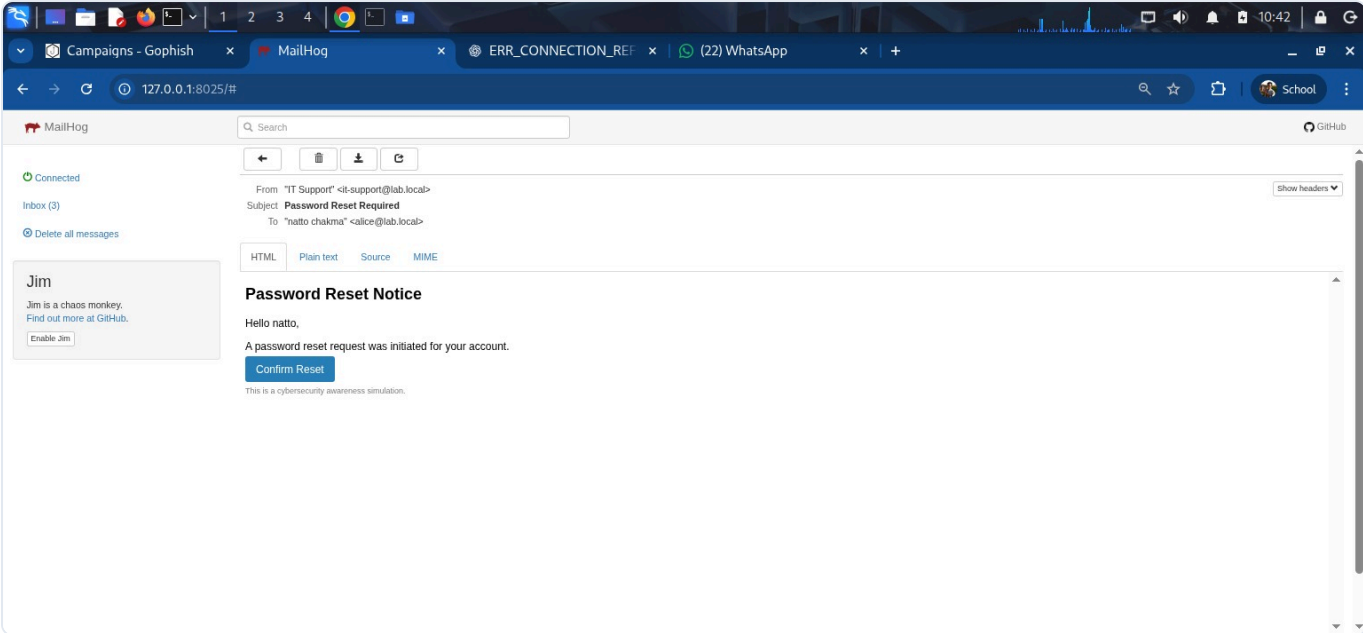


Step 6: Campaign Launch & Real-Time Monitoring

The campaign Password Reset Test - Feb 2026 was launched with target URL <http://127.0.0.1>.



Mail interaction, header generation, and tracking events were validated via MailHog web dashboard (<http://127.0.0.1:8025>).



5. Empirical Results & Vulnerability Metrics

The simulation yielded the following quantitative breakdown across the target audience:

Metric Stage	Count	Percentage	Risk Assessment & Behavioral Meaning
Emails Sent	10	100%	Total simulated phishing emails dispatched via MailHog SMTP.
Emails Opened	7	70%	High curiosity rate; target loaded 1x1 GIF tracking pixel.
Links Clicked	4	40%	Susceptibility rate; targets failed to inspect hyperlinked URL target.
Forms Submitted	2	20%	High-risk credential vulnerability; target entered form data.
Ignored / Reported	3	30%	Security-conscious behavior; email flagged or disregarded.

6. Threat Analysis & Red Flag Identification

▶ Key Indicators of Compromise (IoCs) & Red Flags

- Sender Address Discrepancy:**
- Display name `IT Support` mismatched with domain `it-support@lab.local` or sending host `alerts@bank-lab.local`.
- Urgent Psychological Pretexting:**
- Subject line `Password Reset Required` leverages urgency to bypass critical thinking.
- Suspicious Hyperlink & Protocol:**

6. Button points to HTTP raw loopback IP (`http://127.0.0.1`) rather than an HTTPS official enterprise domain (`https://sso.organization.com`).
7. **Transparent Tracking Pixel (`{{.Tracker}}`):**
8. GoPhish automatically injects `` to detect email open events without user intervention.

7. Defensive Mitigation & Prevention Framework

Technical Security Controls

1. **Email Authentication Standards (SPF, DKIM, DMARC):**
2. **SPF:** Enforce DNS record listing authorized sending IP addresses for organization domains.
3. **DKIM:** Cryptographically sign outgoing mail headers to guarantee message integrity.
4. **DMARC:** Set DMARC policy to `p=reject` to automatically block spoofed domain emails at receiving gateways.
5. **Multi-Factor Authentication (MFA):**
6. Deploy FIDO2 / WebAuthn hardware keys or TOTP authenticator apps. Traditional SMS / Push notification MFA can be bypassed by adversary-in-the-middle (AiTM) proxies, whereas FIDO2 binds domain origin strictly.
7. **Secure Email Gateways (SEG):**
8. Implement dynamic URL rewriting, attachment detonation sandboxing, and AI-driven impersonation headers inspection.

Human & Process Controls

1. **One-Click Phishing Reporting:**
2. Provide an integrated "Report Phishing" button in Microsoft Outlook / Google Workspace for instant SOC escalation.
3. **Continuous Security Awareness Training:**
4. Shift from annual compliance training to quarterly context-driven phishing simulations paired with immediate just-in-time micro-learning feedback.

8. Technical Interview Q&A (Task Assessment)

Q1: What is a phishing attack?

Answer: Phishing is a form of social engineering where attackers disguise themselves as trusted entities (e.g., banks, IT support, executives) using electronic communications (email, SMS, web pages) to deceive targets into revealing sensitive credentials, installing malware, or authorizing financial transactions.

Q2: What are the primary types of phishing attacks?

Answer:

- **Spear Phishing:** Highly customized attacks targeting specific individuals or teams within an organization.
- **Whaling:** Spear phishing specifically targeting senior executives (C-suite, directors).
- **Smishing & Vishing:** Phishing conducted over SMS text messages (Smishing) or voice calls (Vishing).
- **Watering Hole Attack:** Infecting third-party websites frequently visited by target organizations.

Q3: How do SOC analysts and defenders detect phishing attacks?

Answer: SOC teams utilize email gateway logs, DMARC alignment reports, mail header inspections (checking Received: , Return-Path: , Authentication-Results:), endpoint detection and response (EDR) telemetry for malicious attachment behavior, and user-submitted phishing reports.

Q4: Why is phishing considered one of the most dangerous attack vectors?

Answer: Phishing targets human psychology rather than software vulnerabilities. Because humans make decisions based on urgency, fear, or authority, phishing bypasses perimeter firewalls and endpoint controls. A single stolen credential can grant an attacker legitimate access to internal corporate networks.

Q5: What are the key prevention methods against phishing?

Answer: Effective defense requires a multi-layered model: enforcing strict email authentication (SPF, DKIM, DMARC p=reject), implementing domain-bound MFA (FIDO2), using Secure Email Gateways (SEG) with URL rewriting, and conducting regular phishing simulation campaigns.

9. Conclusion

This laboratory successfully demonstrated the full lifecycle of a phishing attack simulation using **GoPhish** and **MailHog**. By capturing metrics across each stage of user interaction, security teams can effectively measure risk exposure and implement actionable technical and educational safeguards.

Report Deliverable Completed for Elevate Labs Task 11